

GadgetZone Admin Dashboard — Build Prompt

Build a fully functional admin dashboard for the **GadgetZone** e-commerce platform (PHP/MySQL, dark theme).

📁 File Structure

...

```
gadget/
├── includes/
│   ├── db.php          # mysqli connection → $conn, starts session
│   ├── currency.php    # Multi-currency config & formatPrice() — required by
functions.php
│   └── functions.php   # Shared helpers (auth, cart, formatting)
└── admin/
    ├── index.php       # Dashboard overview with stats
    ├── products.php    # Product CRUD management
    ├── orders.php      # Order management & status updates
    ├── users.php       # User & role management
    ├── settings.php    # Currency switcher & Stripe key configuration
    ├── layout.php      # Shared admin HTML head + sidebar nav
    ├── footer.php      # Closing tags + admin.js
    ├── admin.css       # Admin-only stylesheet
    ├── admin.js        # Modal, sidebar, preview JS
    └── uploads/        # Product image uploads
...
```

🔑 Key Implementation Notes

- **Admin sidebar logo** is wrapped in `[` — clicking it opens the storefront](/gadget/index.php)
- **Sidebar structure**: logo div → nav links → sidebar-footer (user avatar + name + logout)
- **Auth guard** in `layout.php` checks `role IN ('admin','super\_admin')`, redirects to login otherwise
- **\$pendingOrders** is fetched in `layout.php` and used by sidebar badge + topbar bell icon
- **Default super_admin login**: email = `admin@gadgetzone.com`, password = `Admin@1234`

- Password stored as bcrypt hash:
`\$2y\$10\$IHDQwagf1JxAncjpyZj5oefo9utzJ7AQG0bez9kMXj2aEexbnIFBa`
- If login fails after fresh DB import, the hash must be bcrypt (`\$2y\$10\$...`), NOT MD5
- To reset: `UPDATE users SET password='\$2y\$10\$IHDQwagf1JxAncjpyZj5oefo9utzJ7AQG0bez9kMXj2aEexbnIFBa' WHERE email='admin@gadgetzone.com';`
- **Session stores role at login time** — if role is changed in DB, user must log out and back in to see new role
- **Storefront cart badge** (`<span class="cart-badge">`) is always rendered in DOM, never conditionally — hidden via `style="display:none"` when count=0
- **Cart remove** uses `- **JS base path** auto-detected: `const _BASE = window.location.pathname.startsWith('/gadget') ? '/gadget' : '';` at top of `main.js` — works on localhost AND VPS without any changes

⚙️ Bootstrap Convention

Every admin page starts with:

```
```php
<?php
$pageTitle = 'Page Title – GadgetZone Admin';
require_once __DIR__ . '/../admin/layout.php'; // layout does db + functions + auth
?>
<!-- HTML here -->
<?php require_once __DIR__ . '/../admin/footer.php'; ?>
```
```

`layout.php` itself does:

```
```php
require_once __DIR__ . '/../includes/db.php';
require_once __DIR__ . '/../includes/functions.php';
```
```

🛠️ Available Helper Functions (includes/functions.php)

These functions are already defined and **MUST** be used as-is:

```
```php
```

```
// Auth
isLoggedIn(): bool // checks $_SESSION['user_id']
isAdmin(): bool // role === 'admin' || 'super_admin'
isSuperAdmin(): bool // role === 'super_admin' only
requireLogin(): void // redirects to /gadget/pages/login.php if not logged in
requireAdmin(): void // redirects to /gadget/index.php if not admin
getCurrentUser(): ?array // returns full users row for current session user, or null

// Formatting
formatPrice($amount): string // e.g. "€1,49,999"
sanitize($data): string // real_escape_string + strip_tags + trim
generateOrderNumber(): string // e.g. "GZ-AB12CD-260428"

// Cart (storefront only — not needed in admin)
getCart(), addToCart(), updateCartQty(), removeFromCart(), getCartCount(),
getCartTotal()
...
```

## ## 🎨 Design Aesthetic

- Same dark theme as storefront: `--bg:#0a0a0f`, `--surface:#16161f`,  
`--accent:#f59e0b`
- IBM Plex Sans for headings, DM Sans for body
- Sidebar navigation layout (fixed 240px sidebar + main content area)
- Responsive: sidebar collapses to hamburger on mobile

## ## 🗝️ Access Control

- `layout.php` checks: `\$currentUser['role']` must be `admin` or `super\_admin`
- Redirects to `/gadget/pages/login.php` if not authorized
- Members (`role='member'`) can ONLY access `/gadget/pages/myaccount.php`
- `super\_admin` role can change other users' roles and delete users
- Regular `admin` can manage products and orders but cannot promote/delete users

## ## 📊 DASHBOARD (index.php)

### ### Stat Cards (4 cards in a row)

- Total Products (count from `products` table)
- Total Orders + pending count badge
- Total Revenue (SUM of `total\_amount` where status != 'cancelled')

- Total Users + new this month count

#### ### Recent Orders Table

Columns: Order # | Customer Name | Total | Status badge | Date | View button

Query: JOIN orders with users, LIMIT 8, ORDER BY created\_at DESC

#### ### Top Selling Products Sidebar

Query: SELECT product name, price, COUNT(order\_items) AS sold, GROUP BY product\_id

## ## 📦 PRODUCTS (products.php)

#### ### Features

- Full CRUD: Add, Edit, Delete products
- Search by name + filter by category
- Table: Image thumbnail | Name | Category | Price/Old Price | Stock | Badge | Featured | Actions

#### ### Add/Edit Modal Form (enctype="multipart/form-data")

Fields:

- Product Name \* (generates slug automatically)
- Category \* (dropdown from categories table)
- Price \*, Old Price (optional), Stock \*
- Badge (select: none/NEW/HOT/SALE)
- Featured checkbox
- Description (textarea)
- Image URL input (Unsplash link) with live preview
- OR file upload (jpg/png/webp) — upload overwrites URL

#### ### Delete Safety

- Check `order\_items` table before deleting
- Block deletion if product has orders, show friendly error

#### ### PHP Logic

```
```php
```

```
// Image handling: file upload takes priority over URL
```

```
if (!empty($_FILES['image']['name'])) {
```

```
    $fname = 'prod_' . uniqid() . '.' . $ext;
```

```
    move_uploaded_file($_FILES['image']['tmp_name'], __DIR__ . '/uploads/' . $fname);
```

```
    $imageUrl = '/gadget/admin/uploads/' . $fname;
```

```
}
```

```
// Slug generation
```

```
$slug = strtolower(preg_replace('/[^\a-z0-9]+/i', '-', $name));
```

```
// Always use prepared statements
```

```
$stmt = $conn->prepare("INSERT INTO products
```

```
(name,slug,category_id,price,old_price,stock,badge,featured,description,image_url)
```

```
VALUES (?, ?, ?, ?, ?, ?, ?, ?, ?)");
```

```
$stmt->bind_param('ssiiiddsisd', $name, $slug, $catId, $price, $oldPrice, $stock,  
$badge, $featured, $desc, $imageUrl);
```

```
$stmt->execute();
```

```
````
```

```
🛒 ORDERS (orders.php)
```

```
Features
```

- Paginated order list (15 per page)
- Search by order number or customer name
- Filter by status dropdown
- Inline status update (select dropdown → auto-submits form)
- Detailed order view at `?id=ORDER\_ID`

```
Order Table Columns
```

```
Order # (link) | Customer Name + Email | Items count | Total | Payment | Status (inline
select) | Date | View
```

```
Order Detail View (when ?id= is set)
```

- Customer name, email, phone
- Shipping address
- \*\*Order Notes\*\* (from `orders.notes` column — display if not empty)
- Items table: product image + name | qty | unit price | subtotal
- Grand total
- Status update form

```
Status Values
```

```
`pending` → `processing` → `shipped` → `delivered` | `cancelled`
```

```
Status Badge Colors
```

```
```css
```

```
.badge-pending { background:rgba(245,158,11,0.15); color:#f59e0b }
.badge-processing { background:rgba(59,130,246,0.15); color:#60a5fa }
.badge-shipped { background:rgba(139,92,246,0.15); color:#a78bfa }
.badge-delivered { background:rgba(34,197,94,0.15); color:#4ade80 }
.badge-cancelled { background:rgba(239,68,68,0.15); color:#f87171 }
...
```

👤 USERS (users.php)

Features

- User list with role stats (member count, admin count)
- Search by name or email, filter by role
- Inline role change (super_admin only) — select dropdown auto-submits
- Safe delete (blocks if user has orders)
- Add User modal (first/last name, email, password, role)

Role Hierarchy

Role	Permissions
member	My Account page only
admin	Full admin dashboard (products, orders, users list)
super_admin	Admin + change roles + delete users

Access Control Rule

```
```php
// In layout.php
$currentUser = getCurrentUser();
if (!$currentUser || !in_array($currentUser['role'], ['admin','super_admin'])) {
 header('Location: /gadget/pages/login.php');
 exit;
}
// super_admin check for destructive actions
if (!isSuperAdmin()) { /* block role changes and user deletion */ }
```
```

🖼️ LAYOUT (layout.php)

Sidebar Contains

- Logo with bolt icon

- Navigation: Dashboard, Products, Orders (with pending badge), Users, View Store (new tab)
- Bottom: User avatar with initials, name, role, logout button
- Logout links to `/gadget/pages/logout.php`

Topbar Contains

- Hamburger (mobile only)
- Page title (from `\$pageTitle` variable)
- Bell icon with pending orders badge → links to `orders.php?status=pending`

`\$extraHead` Hook

`layout.php` outputs ``<?=$extraHead ?? " ?>`` inside ``<head>`` — use this in individual pages to inject page-specific ``<style>`` or ``<script>`` tags.

CSS Variables (admin.css)

```
```css
:root {
 --a-bg: #0a0a0f;
 --a-surface: #16161f;
 --a-surface2: #1e1e2a;
 --a-border: rgba(255,255,255,0.08);
 --a-text: #f0f0f5;
 --a-text2: #9090a8;
 --a-text3: #5a5a72;
 --accent: #f59e0b;
 --sidebar-w: 240px;
 --topbar-h: 60px;
}
```
```

JavaScript (admin.js)

```
```javascript
// Modal open/close
function openModal(id) { document.getElementById(id).classList.add('open'); }
function closeModal(id) { document.getElementById(id).classList.remove('open'); }

// Image URL live preview
window.previewImg = function(url) { imgPreview.src = url;
imgPreview.classList.add('show'); };
```

```
// File upload preview (FileReader API)
window.previewFile = function(input) { /* FileReader → set imgPreview.src */ };
...
```

## ## ⚙️ SETTINGS (settings.php)

### #### Features

- **Currency switcher** — visual grid of 12 supported currencies (BDT, USD, EUR, GBP, CAD, AUD, INR, SGD, SAR, AED, JPY, MYR)
- **Stripe key configuration** — Publishable key, Secret key, Webhook secret
- Live currency preview (sample price shown in selected currency)
- Stripe key status indicators (sandbox ✓ / LIVE / Not Set)
- All settings stored in `settings` table (key/value pairs)

### #### Settings Stored in DB

Key	Description
active_currency	Selected currency code (e.g. `USD`)
stripe_publishable_key	Stripe `pk_test_...` or `pk_live_...`
stripe_secret_key	Stripe `sk_test_...` or `sk_live_...`
stripe_webhook_secret	Optional webhook signing secret

### #### Access

- Available to all admins (not restricted to super\_admin)
- Currency change takes effect immediately (session cache invalidated on save)

### #### Stripe Integration Files

File	Purpose
pages/stripe_checkout.php	Creates Stripe Checkout session using DB keys
pages/stripe_return.php	Verifies payment on return, updates order status

---

## ## 🗄️ Database Tables Used

```
```sql
```

```
users → id, first_name, last_name, email, password, phone, address, city, avatar,
role, created_at
```

products → id, category_id, name, slug, description, price, old_price, stock, badge, featured, image_url, created_at
categories → id, name, slug, icon
orders → id, user_id, order_number, total_amount, status, payment_method, shipping_address, notes, stripe_session_id, payment_status, created_at
order_items → id, order_id, product_id, quantity, price
settings → id, setting_key, setting_value, updated_at
...

🔗 Integration Points

- Admin nav link added to `includes/header.php` for admin/super_admin users
- Admin link added to `pages/myaccount.php` sidebar for admins
- `includes/functions.php`: `isAdmin()`, `isSuperAdmin()`, `requireAdmin()`, `getCurrentUser()`, `sanitize()`, `formatPrice()`, `generateOrderNumber()` used throughout
- Product image uploads stored in `admin/uploads/` directory
- ****All queries use `\$conn->prepare()` / `bind\_param()` prepared statements**** — never raw string interpolation for user input

⚠️ Known Gotchas

- `orders.notes` column was added via `ALTER TABLE` after initial setup — always include it in INSERT/SELECT queries
- `layout.php` must be `require\_once`d ****before any HTML output**** to avoid "headers already sent" errors
- Image upload path uses `\_\_DIR\_\_ . '/uploads/'` (absolute) for `move\_uploaded\_file`, but `/gadget/admin/uploads/` (web root relative) for the stored `image\_url`